

## Project Title

### A Multi-Agent LLM Framework for Autonomous Vulnerability Discovery and Verified Remediation in Backend Architectures

Name: Kanaganandini Kanagaraj

Reg\_no: cb.sc.p2cys25011

### Project Title: A Multi-Agent LLM Framework for Autonomous Vulnerability Discovery and Verified Remediation in Backend Architectures

This project elevates automated software testing from simple functional verification to an autonomous security defence system. By pivoting from checking if code works to identifying how it can be compromised, this research addresses the "validation gap" that currently forces security teams to manually verify thousands of potential flaws.

## 1. Problem Statement

Current backend security processes are hindered by three critical bottlenecks:

- **The "Alert Fatigue" Crisis:** Traditional Static Application Security Testing (SAST) tools generate high rates of false positives, overwhelming developers with non-exploitable findings.
- **The Validation Gap:** Proving a vulnerability is "real" (exploitable) currently requires human penetration testers to manually write Proof-of-Concept (PoC) code, a process that does not scale with modern CI/CD speeds.
- **The Remediation Lag:** Traditional scanners identify flaws but do not fix them. Manual patching creates a "dwell time" where the backend remains vulnerable to exploitation while awaiting developer intervention.

## 2. Research and Technical Approach

The project implements a **Multi-Agent Orchestration** strategy using an LLM-driven pipeline (such as LLaMA-3 or GPT-4o) to automate the entire security lifecycle.

### Agentic Architecture:

- **Agent 1: Vulnerability Discovery (The Hunter):** Uses Knowledge-Level Retrieval-Augmented Generation (RAG) to scan source code for risky patterns (e.g., OWASP Top 10) by cross-referencing findings with the latest CVE databases.
- **Agent 2: Exploit Validation (The Red Teamer):** Operates as a "black-box" tester by autonomously generating and executing Python-based exploit scripts or ADB commands. It attempts to "trigger" the vulnerability to confirm its impact, effectively filtering out false positives.

- **Agent 3: Context-Aware Remediation (The Healer):** Generates specialized security patches using Low-Rank Adaptation (LoRA) fine-tuning. It then runs these patches through the original functional testing module to ensure the fix does not break existing application logic.

#### Area of Research:

**Explainable AI (XAI):** Integrating techniques like SHAP or LIME to provide human-readable justifications for every detection, solving the "black-box" problem of neural models in security.

- **Zero-Shot Reasoning:** Leveraging Chain-of-Thought (CoT) to identify "Zero-Day" vulnerabilities—flaws not present in the training data—by reasoning about data-flow dependencies.
- **Adversarial Robustness:** Testing the model's ability to detect obfuscated malicious code (e.g., base64 payloads) to improve its defensive resilience.

### 3. Importance and Impact

- **Industrial Scalability:** This framework enables "Autonomous SOCs" to operate at machine speed, reducing the Mean Time to Response (MTTR) by up to 95% and allowing organizations to bridge the 4.8 million-person global cybersecurity workforce gap.
- **Academic Contribution:** The research addresses the "semantic gap" in automated exploit generation